Machine Translated by Google

Mô-đun 4: Bảo mật đám mây AWS

Nền tảng đám mây của AWS Academy

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Tổng quan về mô-đun

Chủ đề

- Mô hình trách nhiệm chia sẻ của AWS
- Quản lý danh tính và truy cập AWS (IAM)
- Bảo mật tài khoản AWS mới
- Bảo mật tài khoản
- Bảo mật dữ liệu trên AWS
- Làm việc để đảm bảo tuân thủ

Các hoạt động

- Hoạt động mô hình trách nhiệm chia sẻ của AWS

Thử nghiệm

- Bản trình diễn đư ợc ghi lại của IAM

Phòng thí nghiệm

- Giới thiệu về AWS IAM

Kiểm tra kiến thức

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Mục tiêu của mô-đun

Sau khi hoàn thành mô-đun này, bạn sẽ có thể: • Nhận biết mô hình trách nhiệm chung • Xác định trách nhiệm của khách hàng và AWS • Nhận biết người dùng, nhóm và vai trò IAM • Mô tả các loại thông tin xác thực bảo mật khác nhau trong IAM • Xác định các bước để bảo mật tài khoản AWS mới • Khám phá người dùng và nhóm IAM • Nhận biết cách bảo mật dữ liệu AWS • Nhận biết các chương trình tuân thủ AWS

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

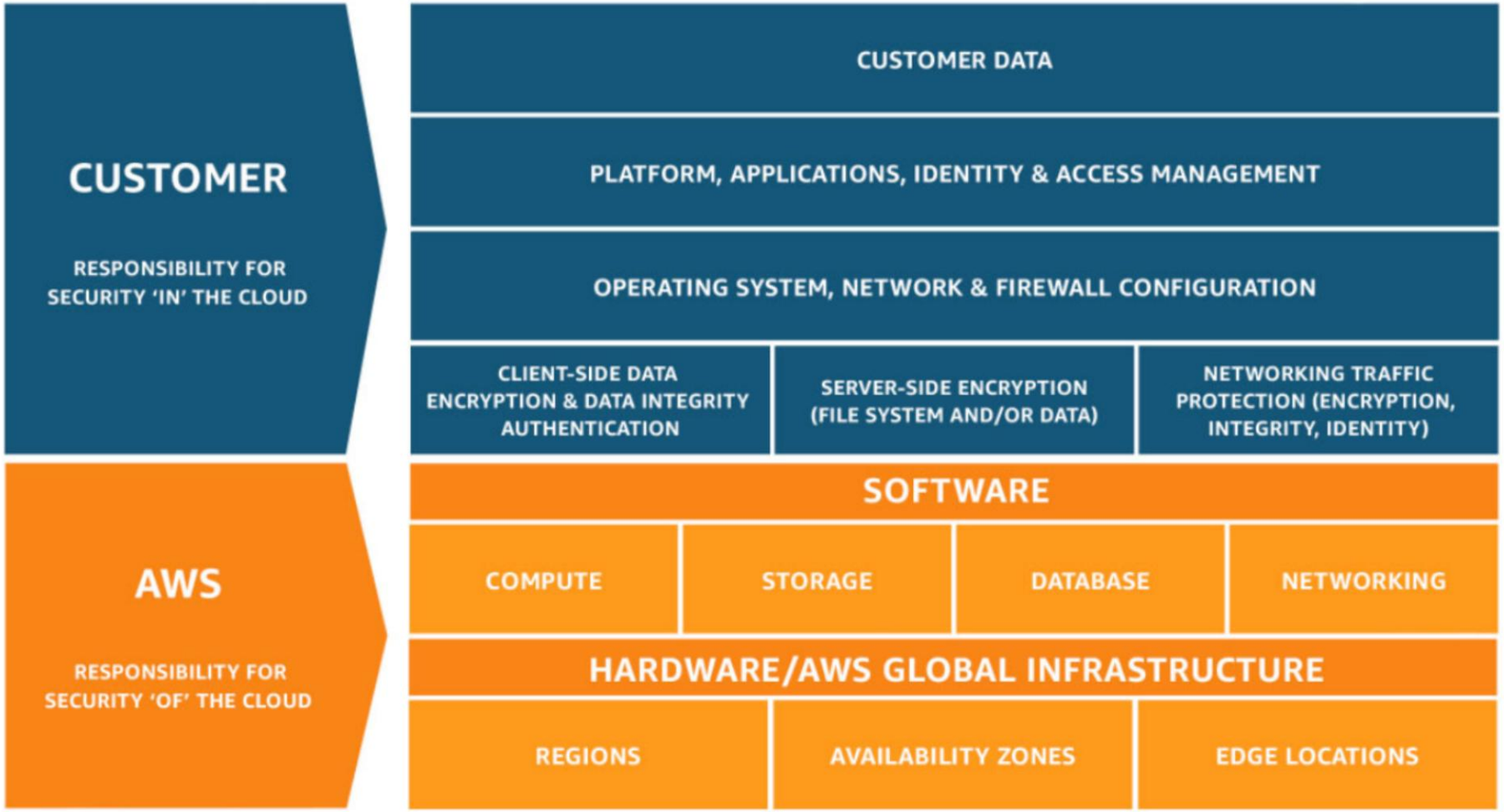
Phần 1: Mô hình chia sẻ trách nhiệm của AWS

Mô-đun 4: Bảo mật đám mây AWS

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

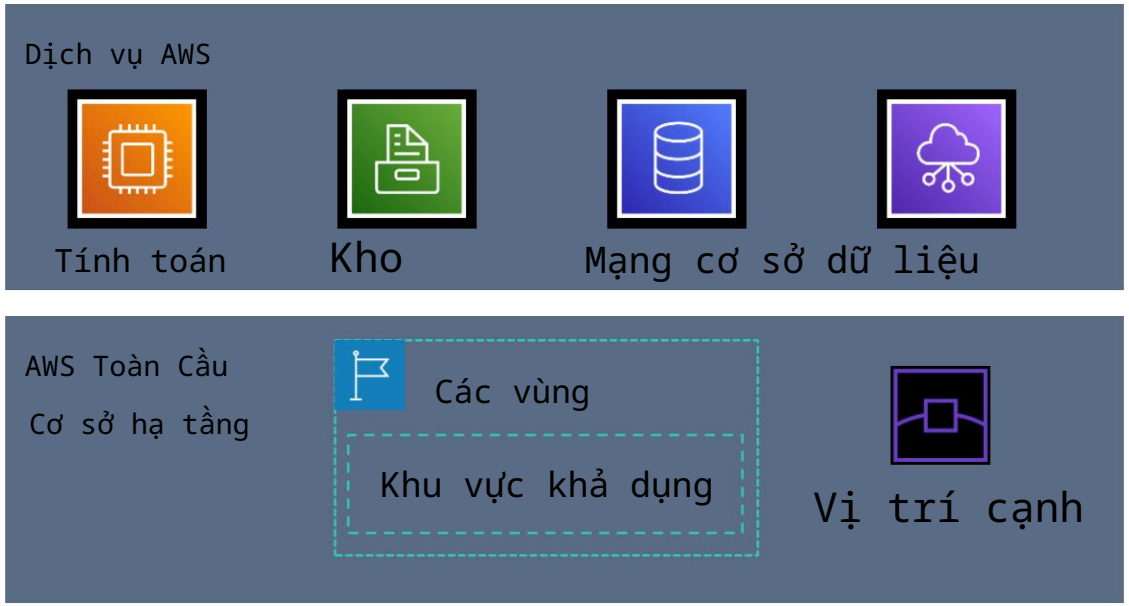
Mô hình chia sẻ trách nhiệm của AWS



© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Trách nhiệm của AWS: Bảo mật của đám mây



Trách nhiệm của AWS:

- Bảo mật vật lý của trung tâm dữ liệu
  - Kiểm soát, truy cập dựa trên nhu cầu
- Cơ sở hạ tầng phần cứng và phần mềm
  - Tháo dỡ lưu trữ, hệ điều hành máy chủ (OS) ghi nhật ký truy cập và kiểm tra
- Cơ sở hạ tầng mạng
  - Phát hiện xâm nhập

- Cơ sở hạ tầng ảo hóa
  - Cô lập trường hợp

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Trách nhiệm của khách hàng: Bảo mật TRONG đám mây

Trách nhiệm của khách hàng:

- Đám mây điện toán đàn hồi của Amazon (Amazon EC2) hệ điều hành phiên bản
  - Bao gồm vá lỗi, bảo trì
- Ứng dụng
  - Mật khẩu, quyền truy cập dựa trên vai trò, v.v.
- Cấu hình nhóm bảo mật
- Tường lửa dựa trên hệ điều hành hoặc máy chủ
  - Bao gồm hệ thống phát hiện hoặc ngăn chặn xâm nhập
- Cấu hình mạng
- Quản lý tài khoản
  - Thiết lập quyền đăng nhập và quyền cho từng người dùng

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Đặc điểm dịch vụ và trách nhiệm bảo mật (1 trong 2)

Ví dụ các dịch vụ do khách hàng quản lý

Amazon EC2

Amazon đàn hồi Cửa hàng Block (Amazon EBS)

Amazon Đám mây riêng ảo (VPC của Amazon)

Cơ sở hạ tầng dư ới dạng dịch vụ (IaaS) • Khách hàng có nhiều sự linh hoạt hơn trong việc cấu hình các thiết lập mạng và lư u trữ

• Khách hàng có trách nhiệm quản lý nhiều khía cạnh hơn của bảo mật

• Khách hàng cấu hình các điều khiển truy cập

Các dịch vụ ví dụ đư ợc quản lý bởi AWS

AWS Lambda

Amazon Cơ sở dữ liệu quan hệ Dịch vụ (Amazon (RDS)

AWS Đàn hồi Cây đậu thần

Nền tảng dư ới dạng dịch vụ (PaaS) • Khách hàng không cần phải quản lý cơ sở hạ tầng cơ bản

• AWS xử lý hệ điều hành, vá lỗi cơ sở dữ liệu, cấu hình tư ờng lửa và phục hồi sau thảm họa

• Khách hàng có thể tập trung vào việc quản lý mã hoặc dữ liệu

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Đặc điểm dịch vụ và trách nhiệm bảo mật (2 trong số 2)

Ví dụ về SaaS

AWS đáng tin cậy Cố vấn

AWS Lá chắn

Tiếng chuông Amazon

Phần mềm dư ới dạng dịch vụ (SaaS)

- Phần mềm đư ợc lư u trữ tập trung
- Đư ợc cấp phép theo mô hình đăng ký hoặc trả tiền khi sử dụng.
- Các dịch vụ thư ờng đư ợc truy cập thông qua trình duyệt web, ứng dụng di động hoặc giao diện lập trình ứng dụng (API)
- Khách hàng không cần phải quản lý cơ sở hạ tầng hỗ trợ dịch vụ

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Hoạt động: Mô hình chia sẻ trách nhiệm của AWS

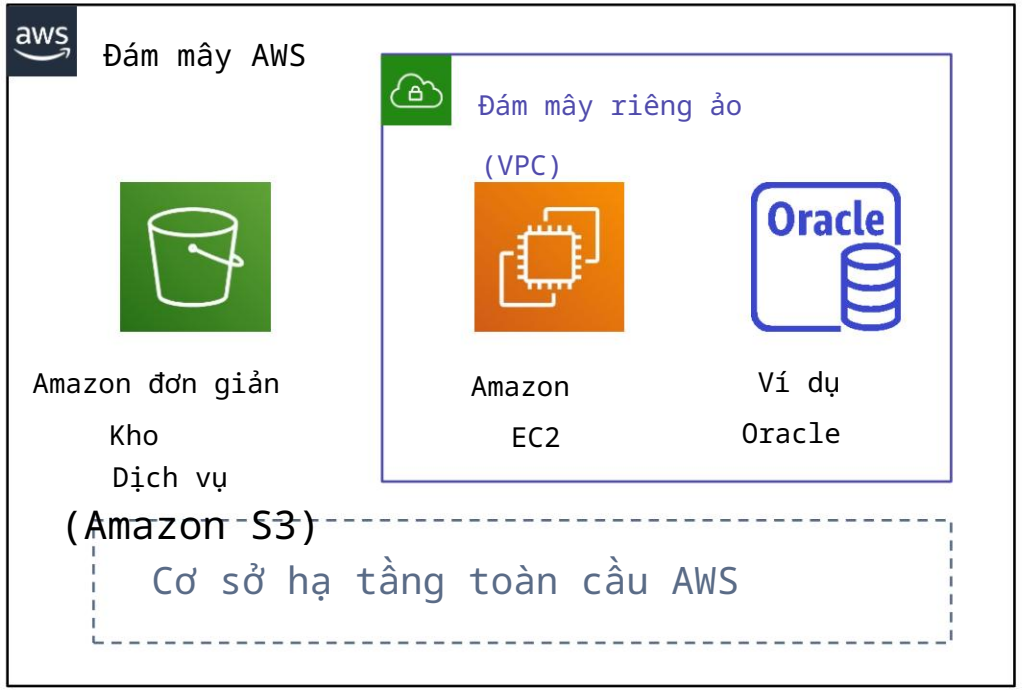
Ảnh của Pixabay từ Pexels.

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Hoạt động: Tình huống 1 trong 2

Hãy xem xét việc triển khai này. Ai chịu trách nhiệm – AWS hay khách hàng?



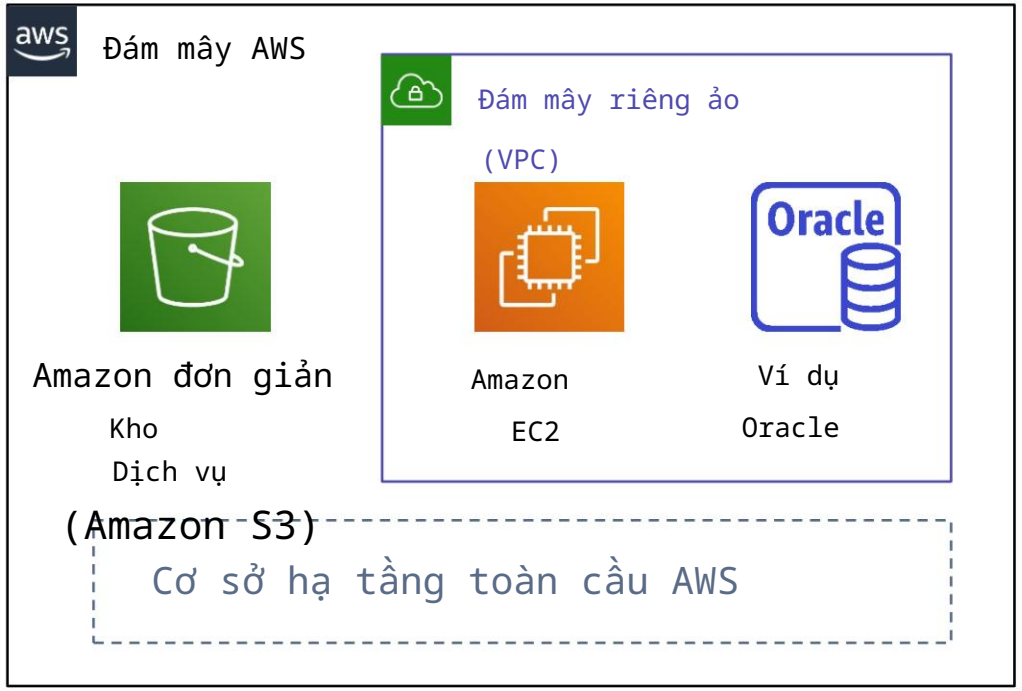
1. Nâng cấp và vá lỗi cho hệ điều hành trên phiên bản EC2?
2. Bảo mật vật lý của trung tâm dữ liệu?
3. Cơ sở hạ tầng ảo hóa?
4. Cài đặt nhóm bảo mật EC2?
5. Cấu hình các ứng dụng chạy trên phiên bản EC2?
6. Nâng cấp hoặc vá lỗi Oracle nếu phiên bản Oracle chạy như phiên bản Amazon RDS?
7. Nâng cấp hoặc vá lỗi Oracle nếu Oracle chạy trên phiên bản EC2?
8. Cấu hình truy cập thùng S3?

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Hoạt động: Tình huống 1 trong 2 câu trả lời

Hãy xem xét việc triển khai này. Ai chịu trách nhiệm – AWS hay khách hàng?



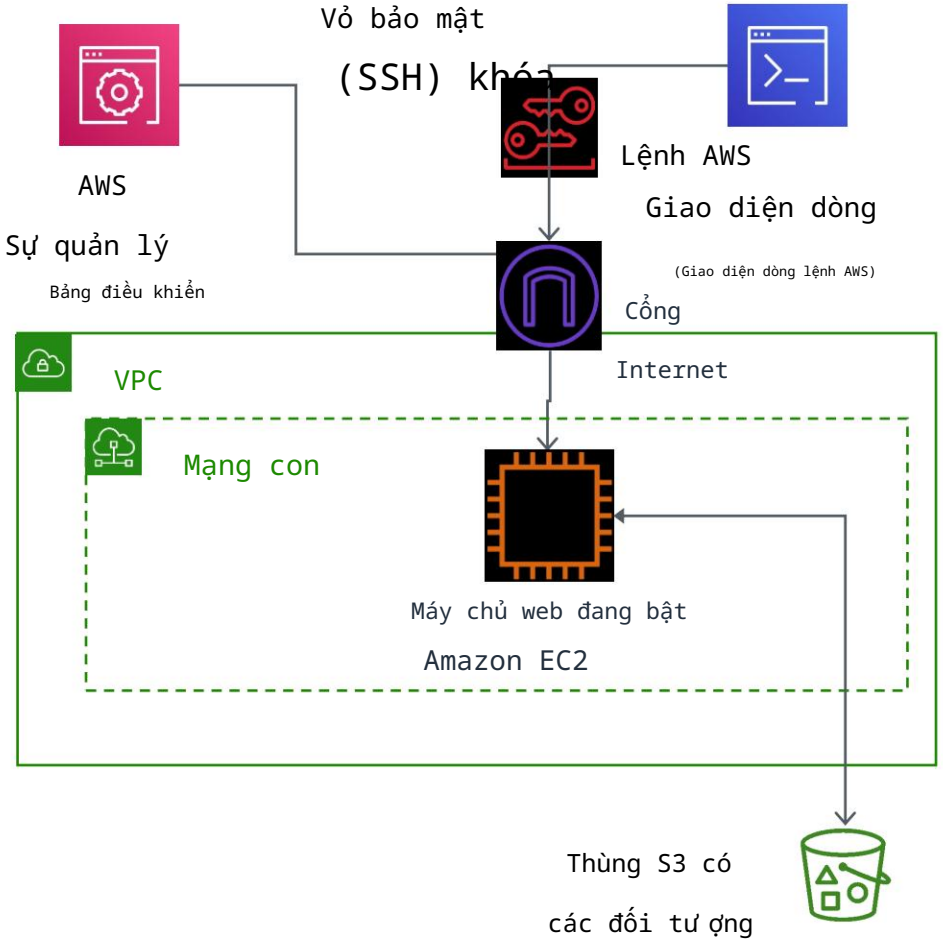
1. Nâng cấp và vá lỗi cho hệ điều hành trên phiên bản EC2?
   - TRẢ LỜI: Khách hàng
2. Bảo mật vật lý của trung tâm dữ liệu?
   - TRẢ LỜI: AWS
3. Cơ sở hạ tầng ảo hóa?
   - TRẢ LỜI: AWS
4. Cài đặt nhóm bảo mật EC2?
   - TRẢ LỜI: Khách hàng
5. Cấu hình các ứng dụng chạy trên phiên bản EC2?
   - TRẢ LỜI: Khách hàng
6. Nâng cấp hoặc vá lỗi Oracle nếu phiên bản Oracle chạy như phiên bản Amazon RDS?
   - TRẢ LỜI: AWS
7. Nâng cấp hoặc vá lỗi Oracle nếu Oracle chạy trên phiên bản EC2?
   - TRẢ LỜI: Khách hàng
8. Cấu hình truy cập thùng S3 ?
   - TRẢ LỜI: Khách hàng

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Hoạt động: Kịch bản 2 trong 2

Hãy xem xét việc triển khai này. Ai chịu trách nhiệm – AWS hay khách hàng?



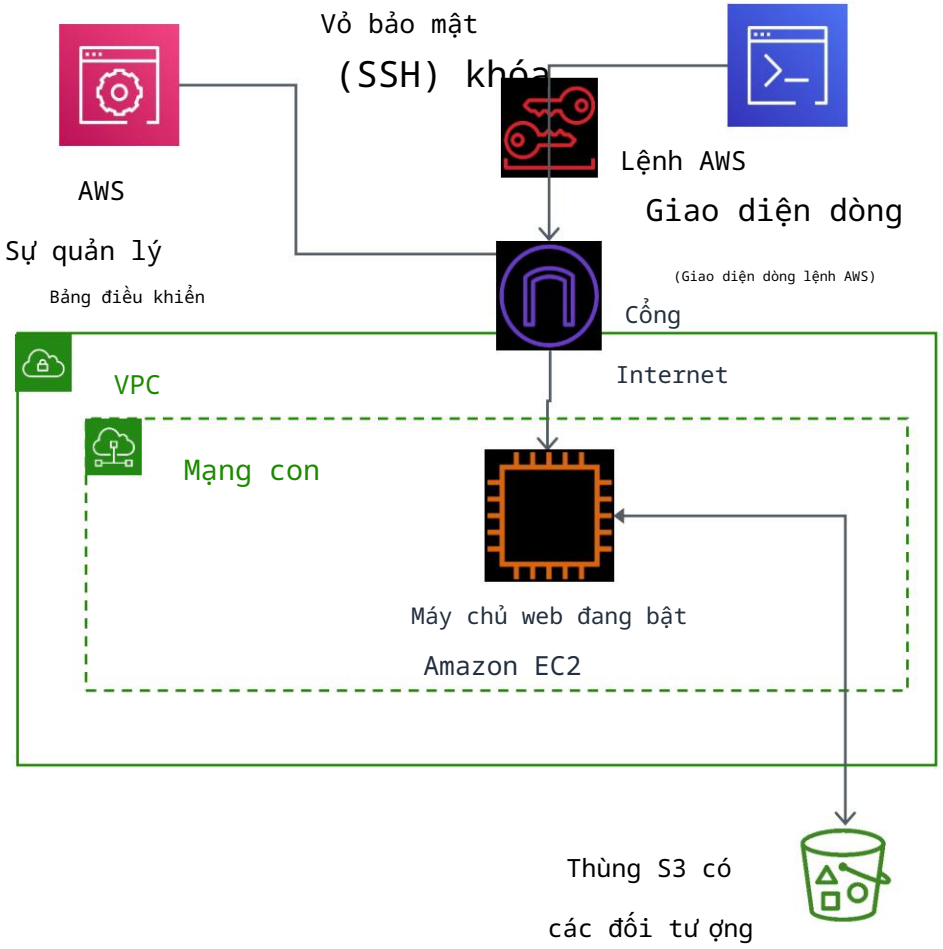
1. Đảm bảo rằng AWS
   Bảng điều khiển quản lý không bị hack?
2. Cấu hình mạng con?
3. Cấu hình VPC?
4. Bảo vệ chống lại sự cố
   mất mạng ở các khu vực AWS?
5. Bảo mật khóa SSH
6. Đảm bảo sự cô lập mạng
   giữa dữ liệu của khách hàng
   AWS?
7. Đảm bảo kết nối mạng có độ
   trễ thấp giữa máy chủ
   web và thùng S3?
8. Thực thi đa yếu tố
   xác thực cho tất cả thông tin đăng nhập của
   ngư ời dùng?

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Hoạt động: Tình huống 2 trong số 2 câu trả lời

Hãy xem xét việc triển khai này. Ai chịu trách nhiệm – AWS hay khách hàng?



1. Đảm bảo rằng AWS Bảng điều khiển quản lý không bị hack?
   - TRẢ LỜI: AWS
2. Cấu hình mạng con?
   - TRẢ LỜI: Khách hàng
3. Cấu hình VPC?
   - TRẢ LỜI: Khách hàng
4. Bảo vệ chống lại sự cố mất mạng ở các khu vực AWS?
   - TRẢ LỜI: AWS
5. Bảo mật khóa SSH
   - TRẢ LỜI: Khách hàng
6. Đảm bảo sự cô lập mạng giữa dữ liệu của khách hàng AWS?
   - TRẢ LỜI: AWS
7. Đảm bảo kết nối mạng có độ trễ thấp giữa máy chủ web và thùng S3?
   - TRẢ LỜI: AWS
8. Thực thi đa yếu tố xác thực cho tất cả thông tin đăng nhập của ngư ời dùng?
   - TRẢ LỜI: Khách hàng

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Phần 1 những điểm chính cần ghi nhớ

- AWS và khách hàng chia sẻ trách nhiệm bảo mật:
  - AWS chịu trách nhiệm về bảo mật của đám mây
  - Khách hàng chịu trách nhiệm về bảo mật trên đám mây
- AWS chịu trách nhiệm bảo vệ cơ sở hạ tầng—bao gồm phần cứng, phần mềm, mạng và cơ sở vật chất—chạy dịch vụ AWS Cloud
- Đối với các dịch vụ được phân loại là cơ sở hạ tầng như một dịch vụ (IaaS), khách hàng có trách nhiệm thực hiện các nhiệm vụ cấu hình và quản lý bảo mật cần thiết
  - Ví dụ, cập nhật hệ điều hành khách và bản vá bảo mật, tường lửa, cấu hình nhóm bảo mật

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Phần 2: AWS Identity and Access Quản lý (IAM)

Mô-đun 4: Bảo mật đám mây AWS

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Quản lý danh tính và truy cập AWS (IAM)

- Sử dụng IAM để quản lý quyền truy cập vào tài nguyên AWS –
  - Tài nguyên là một thực thể trong tài khoản AWS mà bạn có thể làm việc cùng
  - Tài nguyên ví dụ; Một phiên bản Amazon EC2 hoặc một thùng Amazon S3
- Ví dụ – Kiểm soát những ai có thể chấm dứt các phiên bản Amazon EC2
- Xác định quyền truy cập chi tiết –
  - Ai có thể truy cập tài nguyên
  - Những tài nguyên nào có thể đư ợc truy cập và ngư ời dùng có thể làm gì với tài nguyên đó
  - Làm thế nào để có thể truy cập tài nguyên
- IAM là tính năng tài khoản AWS miễn phí

AWS Identity và
Quản lý truy cập
(TÔI LÀ)

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

IAM: Các thành phần thiết yếu

Ngư ời dùng IAM

Một ngư ời hoặc ứng dụng có thể xác thực bằng tài khoản AWS.

Nhóm IAM

Một tập hợp những ngư ời dùng IAM đư ợc cấp quyền giống hệt nhau.

Chính sách IAM

Tài liệu xác định những tài nguyên nào có thể đư ợc truy cập và mức độ truy cập vào từng tài nguyên.

Vai trò IAM

Cơ chế hữu ích để cấp một tập hợp các quyền để thực hiện yêu cầu dịch vụ AWS.

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Xác thực là người dùng IAM để có quyền truy cập

Khi bạn xác định người dùng IAM, bạn chọn loại quyền truy cập mà người dùng được phép sử dụng.

Truy cập theo chương trình

- Xác thực bằng cách sử dụng:
  - ID khóa truy cập
  - Khóa truy cập bí mật
- Cung cấp quyền truy cập AWS CLI và AWS SDK

AWS CLI Công cụ và SDK AWS

Truy cập AWS Management Console

- Xác thực bằng cách sử dụng:
  - ID tài khoản hoặc bí danh gồm 12 chữ số
  - Tên người dùng IAM
  - Mật khẩu IAM
- Nếu được bật, xác thực đa yếu tố (MFA) sẽ nhắc nhập mã xác thực.

Quản lý AWS

Bảng điều khiển

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

MFA của tôi

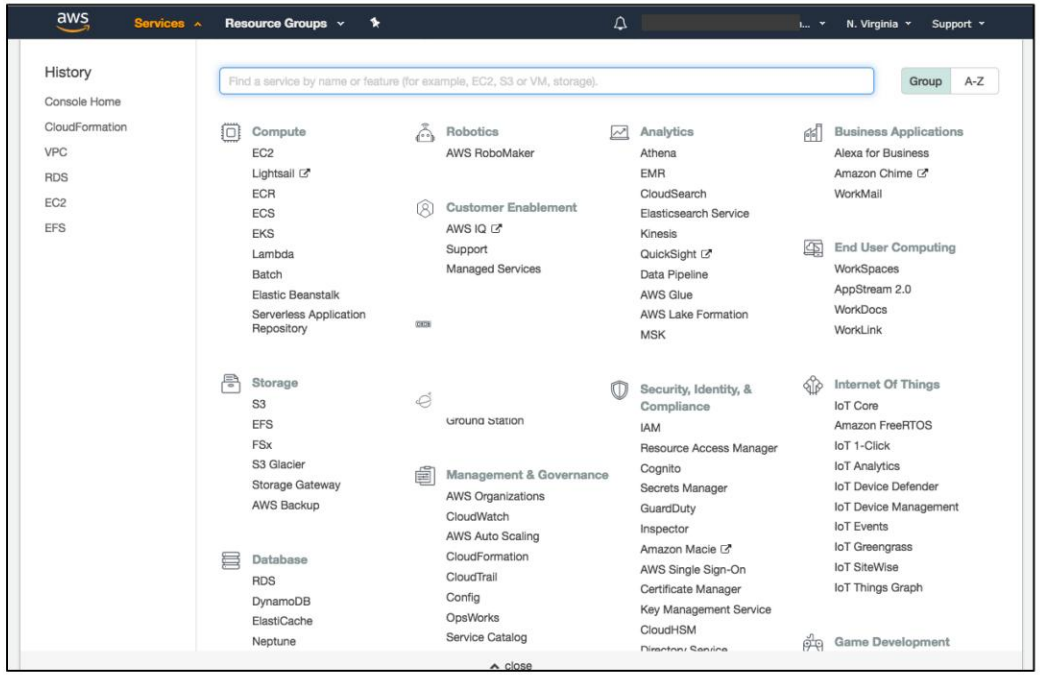
- MFA cung cấp khả năng bảo mật cao hơn.

- Ngoài tên người dùng và mật khẩu, MFA yêu cầu xác thực duy nhất mã để truy cập dịch vụ AWS.

Tên người dùng và mật khẩu

MFA

Mã thông báo MFA



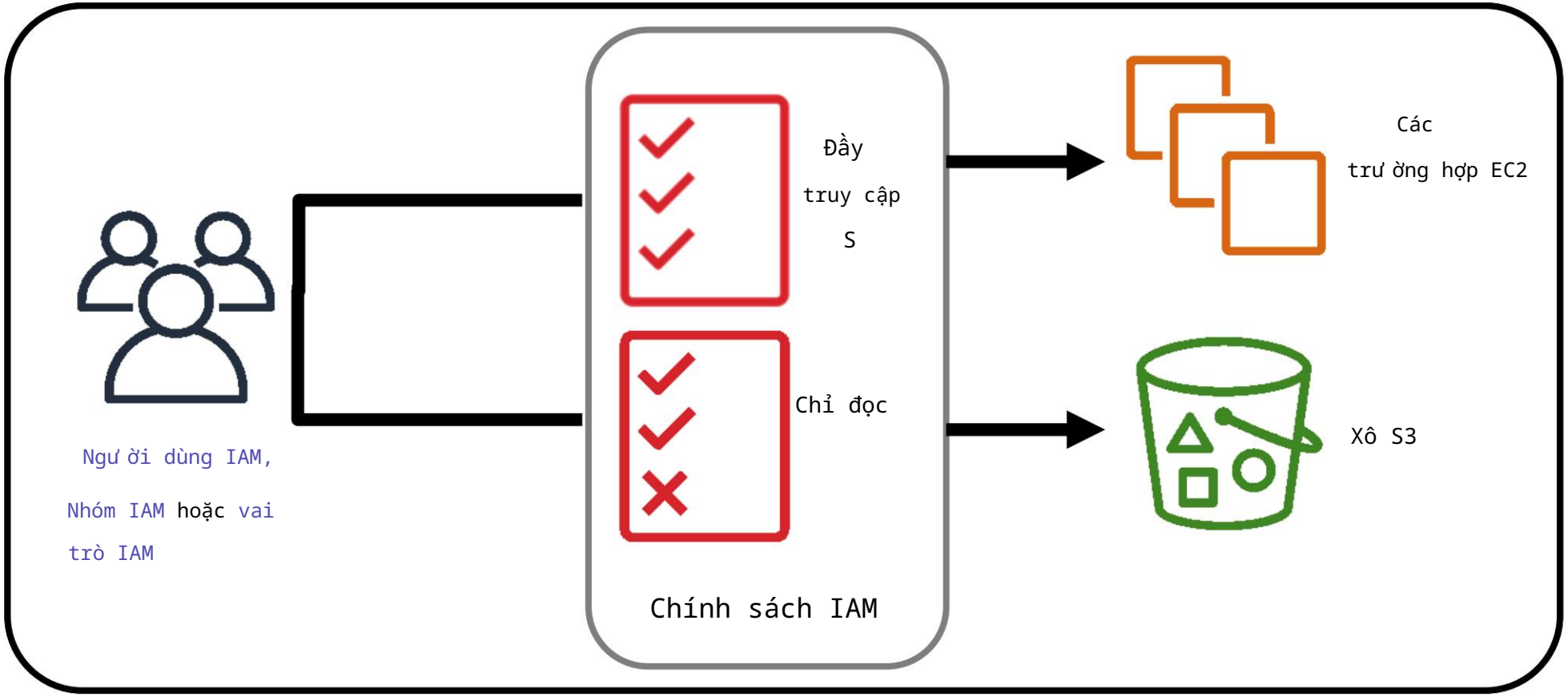
Bảng điều khiển quản lý AWS

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Quyền hạn: Những hành động nào đư ợc phép

Sau khi ngư ời dùng hoặc ứng dụng đư ợc kết nối AWS những gì để tính toán, là họ đư ợc phép làm vậy sao? ĐẾN



© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

IAM: Ủy quyền

- Chỉ định quyền bằng cách tạo chính sách IAM.
- Quyền xác định tài nguyên và hoạt động nào được phép:
  - Theo mặc định, mọi quyền đều bị từ chối ngầm định.
  - Nếu điều gì đó bị từ chối một cách rõ ràng thì nó sẽ không bao giờ được phép.

Thực hành tốt nhất: Thực hiện nguyên tắc đặc quyền tối thiểu.

Quyền

IAM

Lưu ý: Phạm vi cấu hình dịch vụ IAM là toàn cầu. Thiết lập áp dụng trên tất cả các Vùng AWS.

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

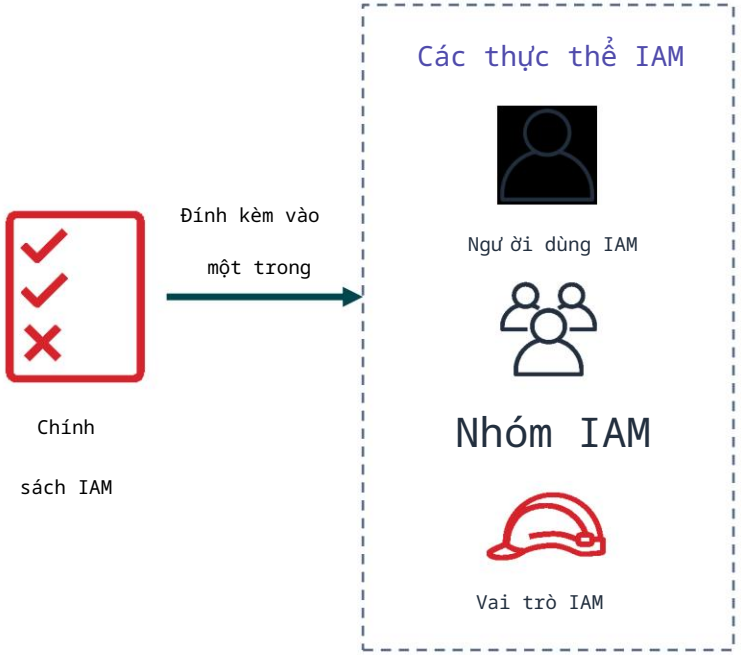
Machine Translated by Google

Chính sách IAM

- Chính sách IAM là một tài liệu xác định quyền
  - Cho phép kiểm soát truy cập chi tiết
- Hai loại chính sách – dựa trên danh tính và dựa trên nguồn lực •

Chính sách dựa trên danh tính –

- Đính kèm chính sách vào bất kỳ thực thể IAM nào
  - Ngư ời dùng IAM, nhóm IAM hoặc vai trò IAM
- Chính sách nêu rõ:
  - Các hành động có thể đư ợc thực hiện bởi thực thể
  - Các hành động mà thực thể không đư ợc thực hiện
- Một chính sách duy nhất có thể đư ợc đính kèm vào nhiều thực thể
- Một thực thể duy nhất có thể có nhiều chính sách đư ợc đính kèm vào nó
- Chính sách dựa trên nguồn lực
  - Đư ợc đính kèm vào một tài nguyên (chẳng hạn như thùng S3)



© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Ví dụ về chính sách IAM

```
{
  "Phiên bản": "2012-10-17", "Câu
  lệnh":[{ "Hiệu
    ứng":"Cho phép", "Hành
    động":["DynamoDB:*","s3:*"], "Tài nguyên":

    [ "arn:aws:dynamodb:region:account-number-without-hyphens:table/table-name", "arn:aws:s3:::bucket-name", .
      thùng Amazon S3. "arn:aws:s3:::bucket-name/*"] }, { "Hiệu ứng":"Từ chối", "Hành
      động":["dynamodb:*","s3:*"], "Không phải

    tài nguyên":
    ["arn:aws:dynamodb:region:account-number-
    without-hyphens:table/table-name", "arn:aws:s3:::bucket-name", "arn:aws:s3:::bucket-name/*"]

    }
  ]
}
```

Quyền cho phép rõ ràng cấp cho ngư ời dùng quyền truy cập vào bảng DynamoDB cụ thể và.

Quyền từ chối rõ ràng đảm bảo rằng ngư ời dùng không thể sử dụng bất kỳ hành động hoặc tài nguyên AWS nào khác ngoài bảng và các thùng đó.

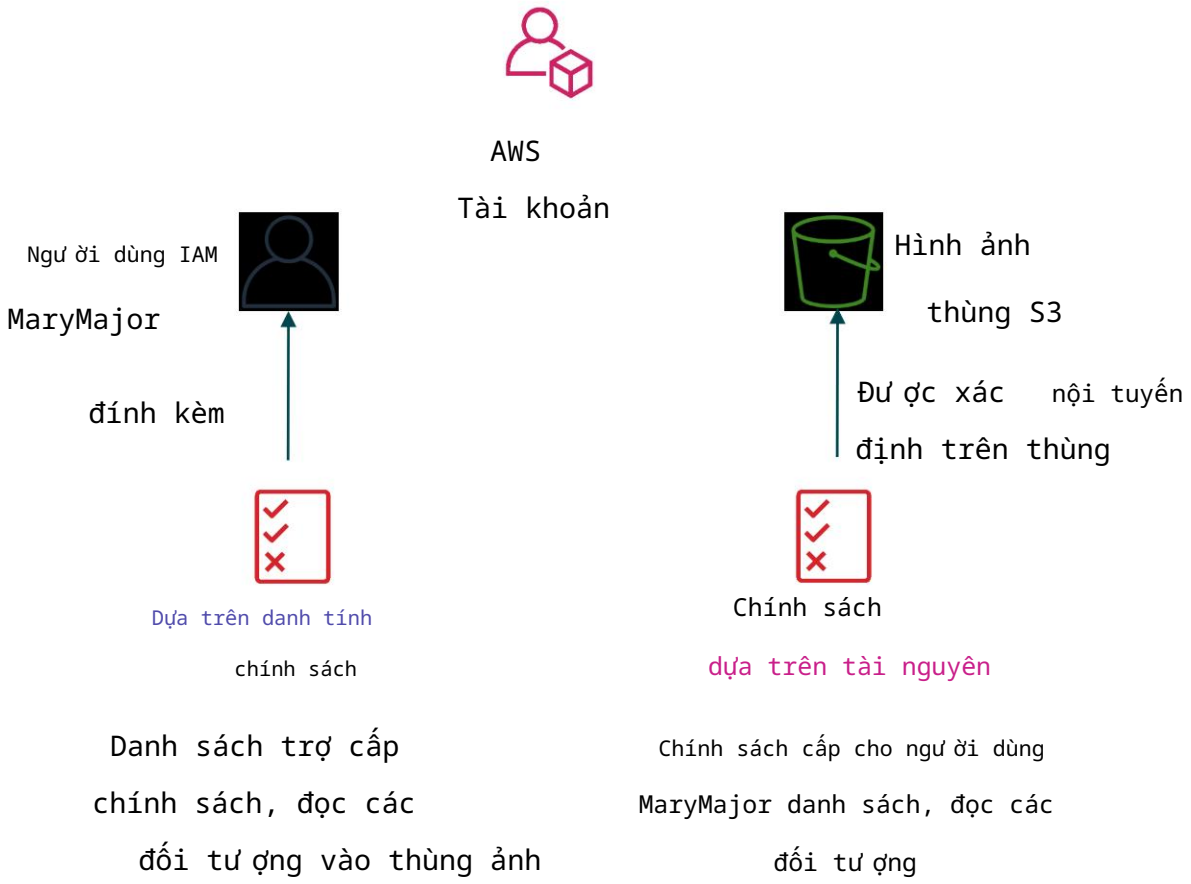
Câu lệnh từ chối rõ ràng có quyền ư u tiên hơn câu lệnh cho phép.

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Chính sách dựa trên tài nguyên

- Chính sách dựa trên danh tính đư ợc đính kèm vào ngư ời dùng, nhóm hoặc vai trò
- Chính sách dựa trên tài nguyên đư ợc đính kèm vào một tài nguyên (không phải vào ngư ời dùng, nhóm hoặc vai trò)
- Đặc điểm của chính sách dựa trên nguồn lực –
  - Chỉ định ai có quyền truy cập vào tài nguyên và những hành động nào họ có thể thực hiện trên đó
  - Các chính sách chỉ là nội tuyến , không đư ợc quản lý
- Chính sách dựa trên tài nguyên chỉ đư ợc hỗ trợ bởi một số dịch vụ AWS

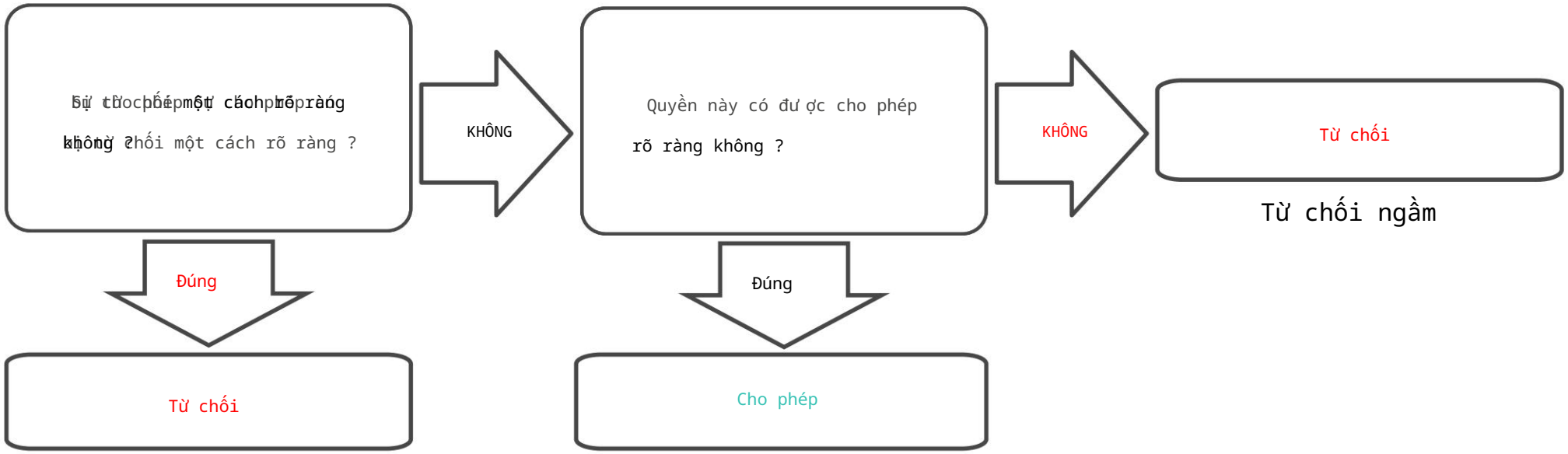


© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Quyền IAM

Cách IAM xác định quyền:



© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

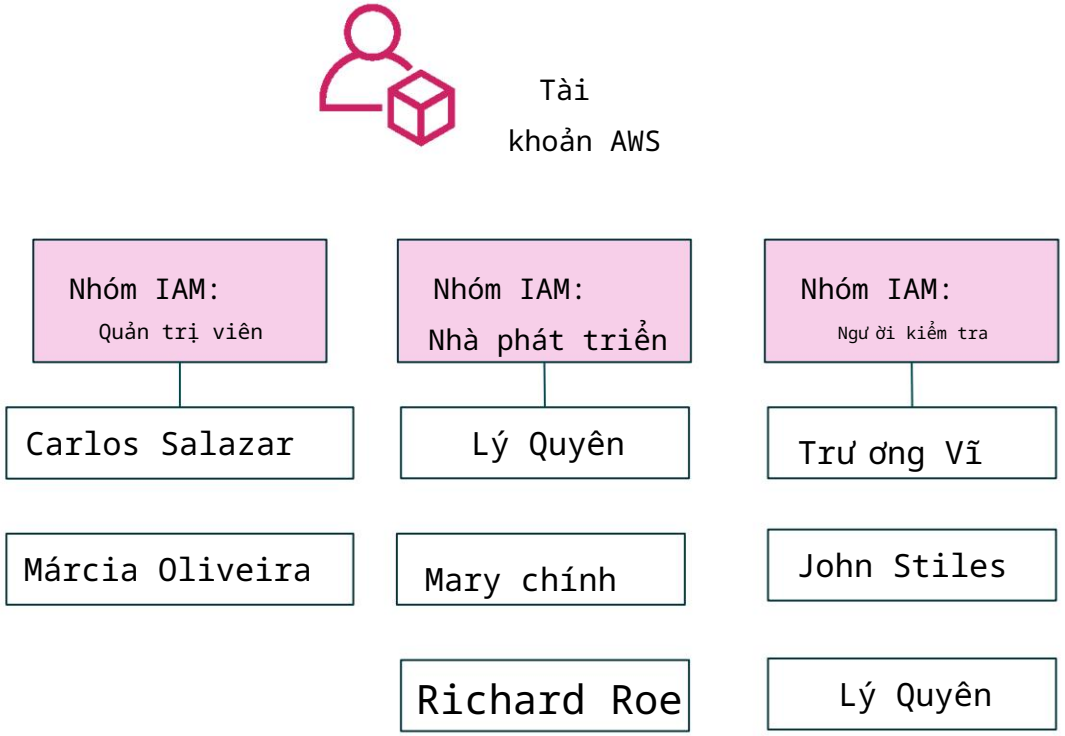
Machine Translated by Google

Nhóm IAM

- Một nhóm IAM là một tập hợp các IAM

  ngư ời sử dụng

- Một nhóm đư ợc sử dụng để cấp cùng một quyền cho nhiều ngư ời dùng
  - Quyền đư ợc cấp bằng cách đính kèm chính sách hoặc các chính sách IAM vào nhóm
- Một ngư ời dùng có thể thuộc nhiều nhóm
- Không có nhóm mặc định
- Các nhóm không thể đư ợc lồng vào nhau



© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Vai trò IAM

- Vai trò IAM là danh tính IAM có các quyền cụ thể • Tư ơng tự như ngư ời dùng IAM
  - Đính kèm chính sách cấp phép vào đó
- Khác với ngư ời dùng IAM
  - Không liên quan duy nhất đến một ngư ời
  - Có ý định đư ợc một ngư ời, ứng dụng hoặc dịch vụ đảm nhiệm
- Vai trò cung cấp thông tin xác thực bảo mật tạm thời • Ví dụ về cách sử dụng vai trò IAM để phân quyền truy cập –
  - Đư ợc sử dụng bởi ngư ời dùng IAM trong cùng một tài khoản AWS với vai trò • Đư ợc sử dụng bởi dịch vụ AWS—chẳng hạn như Amazon EC2—trong cùng một tài khoản với vai trò
  - Đư ợc sử dụng bởi ngư ời dùng IAM trong một tài khoản AWS khác với vai trò

Vai trò IAM

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

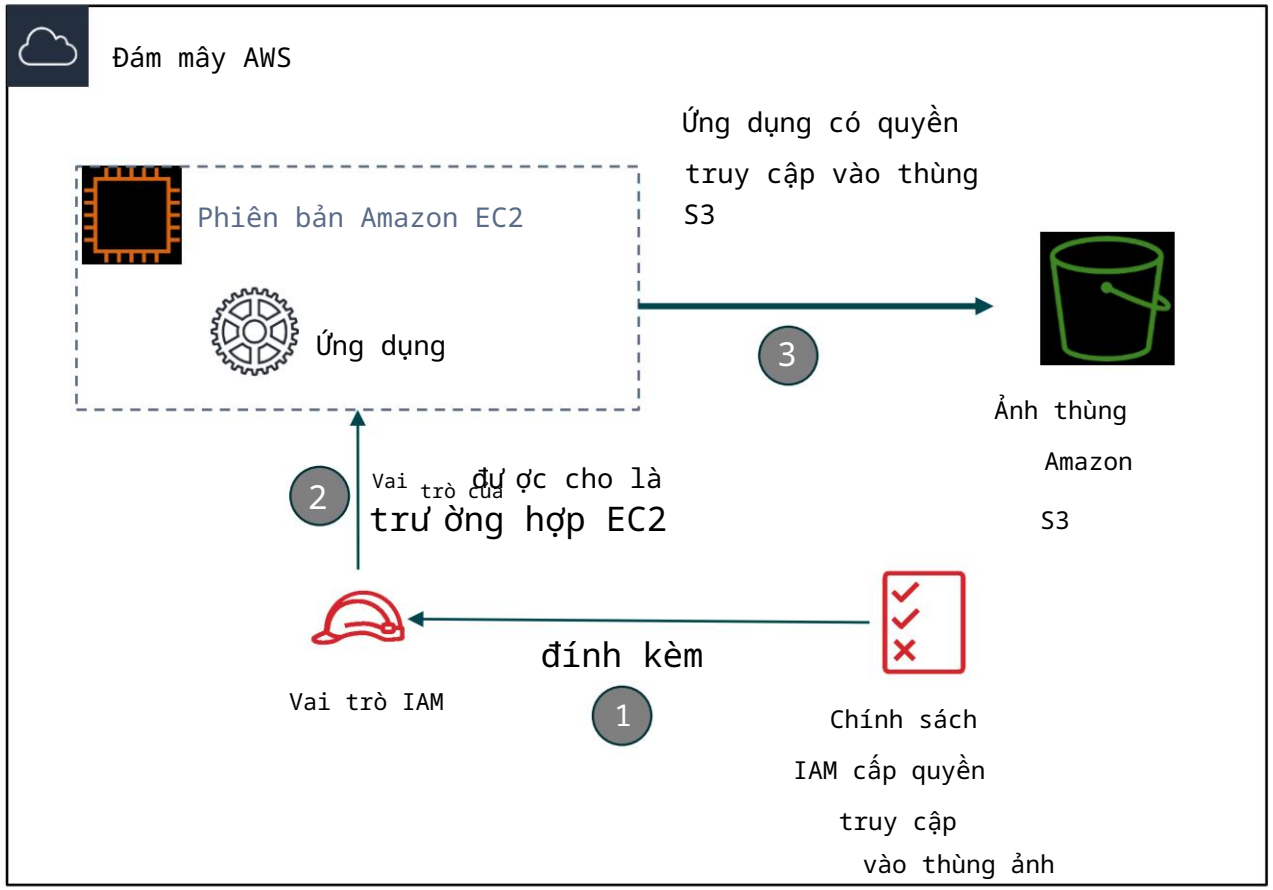
Ví dụ sử dụng vai trò IAM

Kịch bản:

- Một ứng dụng chạy trên EC2 trư ờng hợp cần truy cập vào thùng S3

Giải pháp:

- Xác định chính sách IAM cấp quyền truy cập vào thùng S3.
- Đính kèm chính sách vào vai trò
- Cho phép phiên bản EC2 đảm nhiệm vai trò



© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

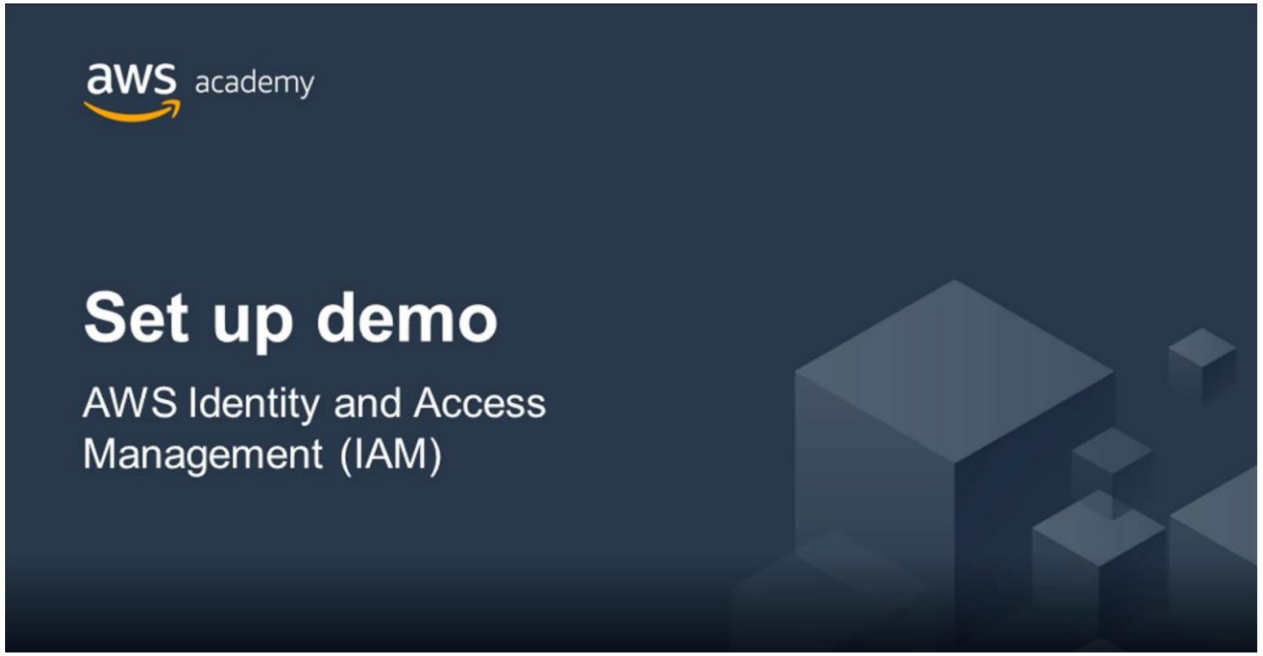
Phần 2 những điểm chính cần ghi nhớ

- Chính sách IAM được xây dựng bằng JavaScript Object Notation (JSON) và xác định quyền.
  - Chính sách IAM có thể được đính kèm vào bất kỳ thực thể IAM nào.
  - Các thực thể bao gồm người dùng IAM, nhóm IAM và vai trò IAM.
- Người dùng IAM cung cấp phương thức để một người, ứng dụng hoặc dịch vụ xác thực với AWS.
- Nhóm IAM là một cách đơn giản để đính kèm cùng một chính sách cho nhiều người dùng.
- Vai trò IAM có thể có chính sách cấp phép kèm theo và có thể được sử dụng để phân quyền truy cập tạm thời cho người dùng hoặc ứng dụng.

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Bản demo đã ghi âm: IAM



© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

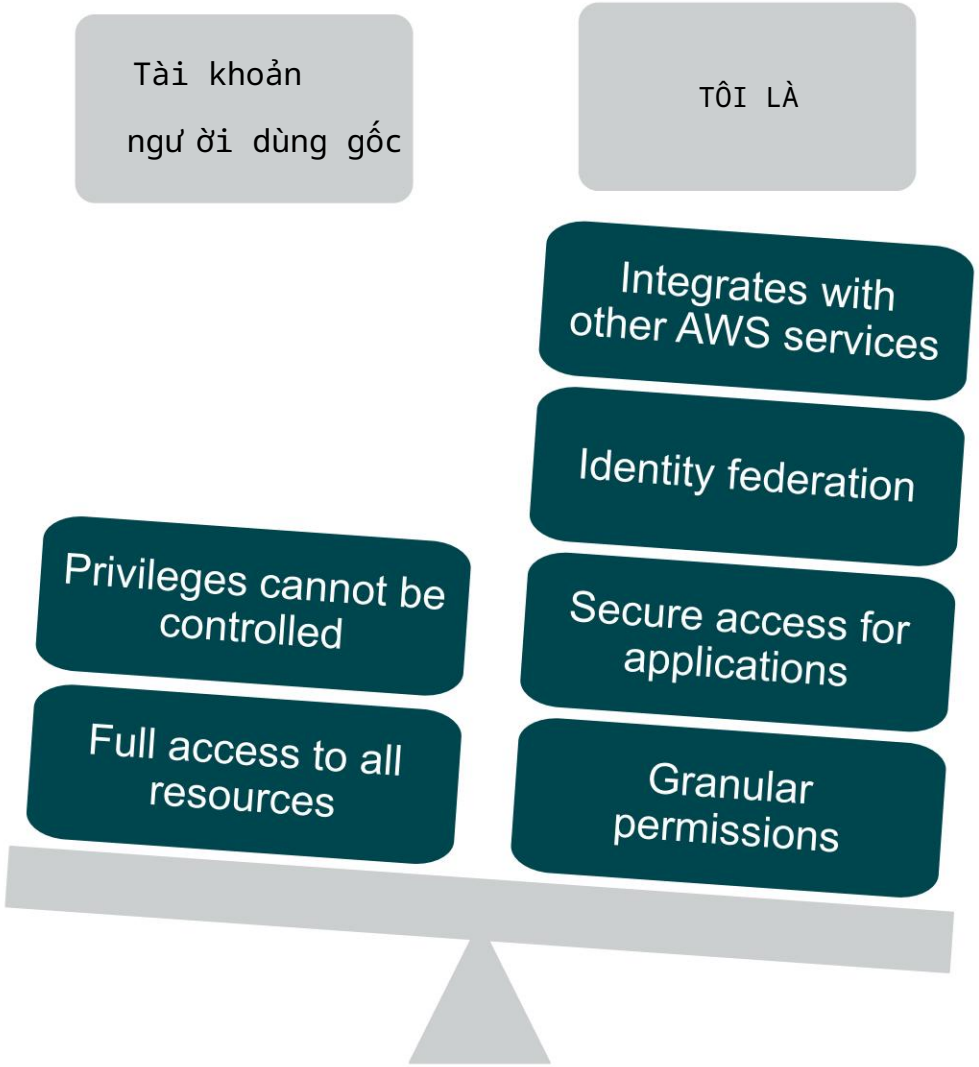
Phần 3: Bảo mật tài khoản AWS mới

Mô-đun 4: Bảo mật đám mây AWS

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Quyền truy cập của ngư ời dùng gốc tài khoản AWS so với quyền truy cập IAM



- Thực hành tốt nhất: Không sử dụng ngư ời dùng gốc của tài khoản AWS trừ khi cần thiết.
  - Để truy cập vào tài khoản ngư ời dùng gốc, bạn phải đăng nhập bằng địa chỉ email (và mật khẩu) mà bạn đã sử dụng để tạo tài khoản.
- Ví dụ về các hành động chỉ có thể thực hiện đư ợc với ngư ời dùng gốc của tài khoản:
  - Cập nhật mật khẩu ngư ời dùng gốc của tài khoản
  - Thay đổi gói hỗ trợ AWS
  - Khôi phục quyền của ngư ời dùng IAM
  - Thay đổi cài đặt tài khoản (ví dụ: thông tin liên hệ, Vùng đư ợc phép)

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Bảo mật tài khoản AWS mới: Người dùng gốc tài khoản

Bước 1: Ngừng sử dụng tài khoản người dùng root càng sớm càng tốt.

- Người dùng gốc của tài khoản có quyền truy cập không giới hạn vào tất cả tài nguyên của bạn.

- Để ngừng sử dụng tài khoản người dùng gốc:

1. Khi bạn đăng nhập với tư cách là người dùng gốc của tài khoản, hãy tạo cho mình một người dùng IAM . Lưu lại khóa truy cập nếu cần.
2. Tạo một nhóm IAM, cấp cho nó toàn quyền quản trị viên và thêm người dùng IAM vào nhóm.
3. Vô hiệu hóa và xóa khóa truy cập người dùng gốc của tài khoản, nếu có.
4. Kích hoạt chính sách mật khẩu cho người dùng.
5. Đăng nhập bằng thông tin người dùng IAM mới của bạn.
6. Lưu trữ thông tin người dùng gốc của tài khoản ở nơi an toàn.

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.

Machine Translated by Google

Bảo mật tài khoản AWS mới: MFA

Bư ớc 2: Bật xác thực đa yếu tố (MFA).

- Yêu cầu MFA cho ngư ời dùng gốc của tài khoản và cho tất cả ngư ời dùng IAM.
- Bạn cũ ng có thể sử dụng MFA để kiểm soát quyền truy cập vào API dịch vụ AWS.

- Các tùy chọn để lấy mã thông báo MFA –
  - Các ứng dụng tuân thủ MFA ảo:
    - Google Authenticator. •

    Authy Authenticator (ứng dụng điện thoại Windows).
  - Thiết bị khóa bảo mật U2F:
    - Ví dụ: YubiKey.
  - Tùy chọn MFA phần cứng:
    - Móc chìa khóa hoặc thẻ hiển thị do Gemalto cung cấp.

Mã thông báo MFA

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Bảo mật tài khoản AWS mới: AWS CloudTrail

Bư ớc 3: Sử dụng AWS CloudTrail.

- CloudTrail theo dõi hoạt động của ngư ời dùng trên tài khoản của bạn.
  - Ghi lại tất cả các yêu cầu API tới các tài nguyên trong tất cả các dịch vụ đư ợc hỗ trợ trong tài khoản của bạn.
- Lịch sử sự kiện AWS CloudTrail cơ bản đư ợc bật theo mặc định và miễn phí.
  - Chứa tất cả dữ liệu sự kiện quản lý trong 90 ngày hoạt động tài khoản gần nhất.
- Để truy cập CloudTrail –

1. Đăng nhập vào AWS Management Console và chọn dịch vụ CloudTrail .
2. Nhấp vào Lịch sử sự kiện để xem, lọc và tìm kiếm sự kiện trong 90 ngày qua.

- Để bật nhật ký sau 90 ngày và bật cảnh báo sự kiện đã chỉ định, hãy tạo một dấu vết.

1. Từ trang theo dõi của CloudTrail Console, nhấp vào Tạo theo dõi.
2. Đặt tên, áp dụng cho tất cả các Vùng và tạo một thùng Amazon S3 mới để lư u trữ nhật ký.
3. Cấu hình các hạn chế truy cập trên thùng S3 (ví dụ: chỉ ngư ời dùng quản trị mới đư ợc phép có truy cập).

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Bảo mật tài khoản AWS mới: Báo cáo thanh toán

Bư ớc 4: Bật báo cáo thanh toán, chẳng hạn như Báo cáo chi phí và sử dụng AWS .

- Báo cáo thanh toán cung cấp thông tin về việc bạn sử dụng tài nguyên AWS và ư ớc tính chi phí cho việc sử dụng đó.
- AWS phân phối báo cáo tới kho lư u trữ Amazon S3 mà bạn chỉ định.
  - Báo cáo đư ợc cập nhật ít nhất một lần mỗi ngày.
- Báo cáo chi phí và mức sử dụng AWS theo dõi mức sử dụng AWS của bạn và cung cấp các khoản phí ư ớc tính liên quan đến tài khoản AWS của bạn, theo giờ hoặc theo ngày.

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền đư ợc bảo lư u.

Machine Translated by Google

Phần 3 những điểm chính cần ghi nhớ

Các biện pháp tốt nhất để bảo mật tài khoản AWS:

- Đăng nhập an toàn với xác thực đa yếu tố (MFA).
- Xóa khóa truy cập của người dùng gốc tài khoản .
- Tạo người dùng IAM riêng lẻ và cấp quyền theo nguyên tắc đặc quyền tối thiểu.
- Sử dụng nhóm để chỉ định quyền cho người dùng IAM.
- Cấu hình chính sách mật khẩu mạnh.
- Phân quyền bằng cách sử dụng vai trò thay vì chia sẻ thông tin xác thực.
- Theo dõi hoạt động của tài khoản bằng cách sử dụng AWS CloudTrail.

© 2022, Amazon Web Services, Inc. hoặc các chi nhánh của công ty. Mọi quyền được bảo lưu.